RGPD : Audit de la société X-Corp

par Ahmed-Aboulanzize Soilahoudine et Abdillah Benali

Jour 1: Qu’est-ce que le RGPD ?

Le RGPD (Règlement Général sur la Protection des Données) est le règlement européen qui protège les données personnelles. Il s’applique depuis le 25 mai 2018 aux entreprises, administrations et associations. Ses objectifs sont de protéger la vie privée, encadrer l’utilisation des données et responsabiliser les organismes.

Une donnée personnelle permet d’identifier une personne directement ou indirectement. Un traitement désigne toute opération sur ces données : collecte, stockage, consultation, modification ou suppression. Les six grands principes sont :

Licéité, loyauté et transparence : les données doivent être traitées de façon légale, sur une base légale valable, et les personnes informées clairement de l'usage qui en est fait.

Limitation des finalités : les données sont collectées pour des finalités déterminées, explicites et légitimes, et ne peuvent pas être réutilisées pour un usage incompatible.

Minimisation des données : on ne collecte que les données strictement nécessaires à la finalité poursuivie, rien de plus.

Exactitude : les données doivent être exactes et tenues à jour ; les données inexactes doivent être corrigées ou effacées.

Limitation de la conservation : les données ne sont conservées que le temps nécessaire à la finalité, puis archivées, anonymisées ou supprimées.

Intégrité et confidentialité (sécurité) : les données doivent être protégées par des mesures techniques et organisationnelles appropriées contre la perte, l'accès non autorisé ou la divulgation.

Jour 2 : Registre des traitements pour X-Corp

X-Corp gère trois traitements principaux : RetailCo pour la gestion clients, HealthMed pour le suivi des patients et EduLearn pour l’analyse de l’usage. Le registre précise les finalités, les personnes concernées, les données collectées, les bases légales et les durées de conservation.

Référence : art. 30 (registre des activités de traitement), **art. 5 §2** (responsabilité / accountability), **art. 24** (responsabilité du responsable du traitement).

Points forts : traitements identifiés, finalités définies, durées de conservation prévues, mesures de sécurité présentes.

Points faibles : registre incomplet, bases légales à vérifier, sous-traitants peu détaillés, transferts hors UE non précisés, incident passé mal géré.

Références : **art. 30** (contenu du registre), **art. 6** (bases légales), **art. 28** (sous-traitants), **art. 44 à 49** (transferts hors UE/EEE), **art. 32** (sécurité des traitements).

Jour 3 : DPIA

La DPIA porte sur le suivi de 500 000 patients par HealthMed avec X-Corp. Les données traitées sont sensibles : identité, coordonnées, historique médical et prescriptions. L’analyse d’impact est nécessaire car il s’agit de données de santé à grande échelle.

Références : **art. 35** (AIPD/DPIA obligatoire en cas de risque élevé), **art. 9** (catégories particulières de données, dont les données de santé), **art. 6** (base juridique du traitement).

Risques principaux : accès non autorisé, fuite de données, modification d’une prescription, perte de données.

Mesures existantes : pseudonymisation, chiffrement, double authentification, RBAC, DPO.

Améliorations : contrôle des accès, surveillance des exports, sauvegardes, sensibilisation au phishing.

Références : **art. 25** (protection des données dès la conception et par défaut), **art. 32** (mesures de sécurité), **art. 35** (analyse des risques et mesures dans l’AIPD), **art. 39** (missions du DPO).

Jour 4 : Simulation de violation de données

Scénario : un technicien X-Corp est victime de phishing. Un jeton de session est volé. L'attaquant accède à DataManage et exporte 2 000 dossiers HealthMed. Données exposées : identité, coordonnées, rendez-vous, données médicales et prescriptions.

Références : **art. 4, point 12** (définition d'une violation de données personnelles), **art. 32** (sécurité), **art. 33** (notification à l'autorité de contrôle), **art. 34** (information des personnes concernées).

Actions immédiates : désactiver le compte, révoquer les sessions, bloquer l’adresse IP, suspendre les exports, préserver les preuves.

X-Corp informe HealthMed. HealthMed notifie la CNIL sous 72 heures et informe les patients si le risque est élevé.

Références : **art. 33 §1** (notification sous 72 heures), **art. 33 §2** (obligation du sous-traitant d’informer le responsable), **art. 34** (communication aux personnes en cas de risque élevé), **art. 28** (obligations contractuelles du sous-traitant).

Jour 5 : Audit RGPD de X-Corp

Résultat : conformité partielle.

Points positifs : DPO, registre, chiffrement, pseudonymisation, RBAC, DPIA.

Points faibles : bases légales, registre incomplet, droits des personnes, sous-traitance CloudSecure, comptes privilégiés, exports massifs.

Références : **art. 5 §2** (accountability), **art. 24** (responsabilité), **art. 30** (registre), **art. 32** (sécurité), **art. 35** (AIPD), **art. 37 à 39** (DPO).

Priorités : compléter le registre, vérifier les bases légales, renforcer les accès privilégiés, contrôler les exports, auditer CloudSecure, automatiser les suppressions, améliorer la gestion des droits et tester les incidents.

Conclusion : conformité conditionnelle.

Références : **art. 24** (mise en œuvre et réexamen des mesures), **art. 25** (privacy by design/default), **art. 32** (sécurité), **art. 35** (mise à jour de l'AIPD), **art. 36** (consultation préalable de la CNIL si risque élevé résiduel), **art. 83** (sanctions administratives).